

VirtuEx 시스템 감사 보고서 (25차)

VirtuEx System Audit Report (25th)

- 감사일: 2026-03-31
- 감사 범위: 24차 미수정 항목 재검증, CSP nonce/hydration, WebSocket Strict Mode, 프론트엔드 타입 안전성, 대시보드 UX, 실시간 가격 스토어
- 감사 방법: 전체 소스 코드 정적 분석 + 런타임 콘솔 검증 + 브라우저 DevTools 확인
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 24차 미수정 6건 중 5건 수정 완료. 신규 발견 4건 수정 완료.

이전 감사 대비 수정 현황 (24차 → 25차)

이전 이슈	상태	비고
[SEC-H-03] 응답 바디에 accessToken 노출 — httpOnly 쿠키 보안 우회	미수정 (의도적)	WebSocket handshake에 필요 — 제거 시 실시간 가격/채팅 전체 장애. 쿠키 기반 인증이 주 경로이며 바디 토큰은 WebSocket 전용 보조 경로로 유지
[ERR-M-01] 주문 프로시저 거래 알림 실패 시 내부 에러 메시지 로깅	수정됨	order-proxy.controller.ts에서 Logger.warn()으로 내부 로깅만 수행, 클라이언트 응답에 에러 메시지 미노출 확인
[ERR-M-02] proxy controller any 타입 사용	수정됨	AuthenticatedRequest 인터페이스 신규 생성 (proxy/interfaces/authenticated-request.interface.ts). portfolio-proxy.controller.ts 전체 10개소 Record<string, any> → AuthenticatedRequest 교체. FeedActivity, FeedUserInfo 타입 도입 확인
[ERR-L-01] 프론트엔드 catch 블록 에러 무시 패턴	수정됨 (이전 작업)	portfolio/page.tsx에서 console.debug('[portfolio] Query error:', err) 로깅 추가 확인
[AUTH-L-01] 공개 포트폴리오 API 보유 자산 상세 노출	수정됨	portfolio-proxy.controller.ts에서 공개 포트폴리오 응답 후처리 — 절대 수량(quantity, value) 제거, 비율 기반 allocation(%) + sizeCategory("large"/"medium"/"small")로 마스킹 확인
[SVC-M-01] 서비스 간 HTTP 통신 HTTPS 미적용	미수정 (의도적)	Docker 내부 네트워크 한정 — 외부 미노출. HTTPS 적용 시 자체 서명 인증서 인프라 필요. 단일 호스트 Docker Compose 환경에서 리스크 대비 비용 비합리적
[FE-M-02] 주문 폼 최대 수량 계산 환율 오차	수정됨	OrderForm.tsx에서 Math.floor((cashBalance / safeCurrentPrice) * 0.995 * 100) / 100 적용 — 0.5% 안전 버퍼 확인

[MISC-L-01] 공지사항 Gateway AdminRolesGuard 미적용	수정됨	announcement-proxy.controller.ts에 @UseGuards(AdminRolesGuard) — POST/PUT/DELETE/PIN/첨부파일 6개 관리 엔드포인트 적용 확인. GET(목록/상세/인접), 좋아요, 조회수, 댓글은 공개 유지
[AUD-M-01] 비밀번호 재설정 감사 로깅 불충분	수정됨	auth.service.ts에서 resetPassword() 내 7가지 실패 사유(비밀번호 불일치, 길이 부족, 소문자/숫자/특수문자 누락, 세션 만료, SMS 미인증)별 this.logger.warn() 추가 확인. 세션/사용자 식별자 포함, 비밀번호 미포함

24차 미수정 6건 → 5건 수정, 1건 의도적 유지 (SEC-H-03)

25차 신규 발견 및 수정 항목

[CSP-25-01] CSP middleware 개발모드 호환성 (Medium, 수정됨)

발견: script-src 에 'unsafe-eval' 미포함 → 개발 모드에서 Next.js React Refresh (HMR)가 CSP에 의해 차단. connect-src 에 http://localhost:3000 미포함 → 프론트(4000) → API Gateway(3000) 요청이 다른 출처로 차단.

수정: middleware.ts 에서 process.env.NODE_ENV === 'development' 체크 — 개발 모드에서만 'unsafe-eval' + http://localhost:3000 ws://localhost:3000 추가. 프로덕션에서는 포함되지 않아 보안 유지.

파일: frontend/src/middleware.ts

[HYD-25-01] Layout hydration mismatch — nonce 불일치 (Low, 수정됨)

발견: <Script nonce={nonce}> 사용 시 서버는 nonce="실제값", 클라이언트는 nonce="" (브라우저 보안 정책상 DOM에서 nonce 속성값 제거). React가 hydration mismatch 경고 발생.

수정: next/script 의 <Script> → raw <script> 태그로 교체 + suppressHydrationWarning 적용. nonce는 그대로 전달되어 CSP 정책 정상 동작.

파일: frontend/src/app/layout.tsx

[WS-25-01] WebSocket Strict Mode 이중 연결 경고 (Low, 수정됨)

발견: React 19 Strict Mode(개발 모드)가 Effect를 마운트 → 언마운트 → 재마운트로 2번 실행. 첫 마운트에서 생성된 소켓이 즉시 disconnect되면서 "WebSocket is closed before the connection is established" 콘솔 경고 발생.

수정: useWebSocket.ts + useChatSocket.ts 에서 autoConnect: false 설정 + disposed 플래그 도입. cleanup 시 소켓이 연결을 시도하기 전에 중단되므로 "연결 전 닫힘" 경고 제거.

파일: frontend/src/hooks/useWebSocket.ts , frontend/src/hooks/useChatSocket.ts

[PRICE-25-01] 실시간 가격 스토어 객체 참조 동일성 문제 (Medium, 수정됨)

발견: batchUpdatePrices() 에서 priceMap.set(symbol, update) — 동일 객체 참조가 저장되면 useSyncExternalStore 의 Object.is() 비교에서 변경 미감지. 등락률 배경색 등 파생 UI가 갱신되지 않음.

수정: priceMap.set(symbol, { ...update }) — 항상 새 객체 참조 생성으로 변경 감지 보장.

파일: frontend/src/stores/livePrice.ts

[UX-25-01] 대시보드 테이블 종목명 잘림 + 데이터 생략 (Low, 수정됨)

발견: 종목명 컬럼 너비가 모바일/데스크톱 모두 부족하여 "삼성바...", "현대자..." 등 잘림 발생. 숫자 컬럼에 truncate 클래스로 금액이 "..."으로 생략.

수정:

- 종목명: 모바일 150px / sm 160px / md 180px / lg 220px
- 숫자 컬럼: truncate 제거, 모바일에서 고정 너비 대신 자동 너비 + whitespace-nowrap
- spacer min-w 제거로 종목명-현재가 간 빈 공간 최소화

파일: frontend/src/components/market/AssetList.tsx ,
frontend/src/components/market/AssetListItem.tsx

[UX-25-02] 등락률 배경색 영구 고정 문제 (Medium, 수정됨)

발견: isExtreme ([changePercent] >= 5%) 조건으로 배경색(bg-rise/10 , bg-fall/10)이 영구 적용. 암호화폐처럼 변동률이 항상 5% 이상인 종목은 배경이 영원히 유지됨.

수정: isExtreme 기반 영구 배경 완전 제거. 등락률은 텍스트 색상(빨강/파랑)만 유지. 현재가 플래시는 CSS tick-flash-rise / tick-flash-fall 애니메이션으로 자연스럽게 유지. 동일 금액 틱 시 플래시 안 발생하도록 이전값 비교 추가.

파일: frontend/src/components/market/AssetListItem.tsx

[UX-25-03] 실시간 변동률 계산 정확도 (Medium, 수정됨)

발견: displayAsset.changePercent 에서 live.changePercent ?? asset.changePercent 사용 — WebSocket이 changePercent: 0 을 보내면 ?? 연산자가 0을 유효값으로 인식하여 원래 값을 덮어씀. 또한 WebSocket 이 changePercent 를 누락하면 초기값이 영원히 유지.

수정: 기준가(전일 종가)를 역산하여 실시간 가격에서 changePercent 를 직접 계산. live.changePercent !== 0 이면 WebSocket 값 사용, 아니면 (livePrice - basePrice) / basePrice * 100 계산값 사용.

파일: frontend/src/components/market/AssetListItem.tsx

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안 (의도적 유지)	0	1	0	0	1
B. 서비스 간 통신 (의도적 유지)	0	0	1	0	1
잔존 이슈 합계	0	1	1	0	2

의도적 미수정 항목 (2건)

ID	항목	심각도	사유
SEC-H-03	응답 바디 accessToken 노출	High	WebSocket handshake 인증에 필수. 제거 시 실시간 가격/채팅 전체 장애
SVC-M-01	서비스 간 HTTP 통신	Medium	Docker 내부 네트워크 한정. HTTPS 인증서 인프라 비용 대비 리스크 낮음

CSP style-src 관련 (참고)

24차에서 지적된 CSP-M-01 unsafe-inline + strict-dynamic 공존 은 24차에서 이미 수정됨 (unsafe-inline 제거, nonce 기반 전환). 단, style-src 'unsafe-inline' 은 Next.js 인라인 스타일 의존으로 유지 중 — 이는 script-src 가 아닌 style-src 이므로 XSS 위험도가 낮으며, Next.js 아키텍처 제약으로 분류.

25차 수정 완료 항목 전체 목록

#	ID	항목	심각도	유형
1	ERR-M-01	주문 프록시 에러 메시지 내부 로깅만	Medium	24차 잔존
2	ERR-M-02	proxy controller any → AuthenticatedRequest	Medium	24차 잔존
3	ERR-L-01	catch 블록 에러 로깅 추가	Low	24차 잔존 (이전 수정)
4	AUTH-L-01	공개 포트폴리오 수량 마스킹	Low	24차 잔존
5	FE-M-02	주문 최대 수량 0.5% 안전 버퍼	Medium	24차 잔존
6	AUD-M-01	비밀번호 재설정 실패 감사 로깅	Medium	24차 잔존
7	MISC-L-01	공지사항 AdminRolesGuard 적용	Low	24차 잔존
8	CSP-25-01	CSP 개발모드 unsafe-eval + connect-src	Medium	25차 신규
9	HYD-25-01	Layout nonce hydration mismatch	Low	25차 신규
10	WS-25-01	WebSocket Strict Mode 이중 연결 경고	Low	25차 신규
11	PRICE-25-01	가격 스토어 객체 참조 동일성	Medium	25차 신규
12	UX-25-01	대시보드 종목명/데이터 찢림	Low	25차 신규
13	UX-25-02	등락률 배경색 영구 고정	Medium	25차 신규
14	UX-25-03	실시간 변동률 계산 정확도	Medium	25차 신규

총 14건 수정 완료 (24차 잔존 7건 + 25차 신규 7건)